Detectando lo que las reglas y las líneas base no ven: UEBA basado en series de tiempo

Alejandro Higuera Castro

Departamento de Estadística, Facultad de Ciencias
Universidad Nacional de Colombia, Sede Bogotá, Colombia
ahiguerac@unal.edu.co

Resumen Los centros de operaciones de seguridad (SOC) buscan amenazas internas con reglas de umbral y líneas base estáticas que generan tantas falsas alarmas que desgastan y desensibilizan a los analistas. Este trabajo trata la actividad de cada usuario como una serie de tiempo con ciclo semanal y aplica la metodología Box-Jenkins a la analítica del comportamiento de usuarios (UEBA): cada noche, un modelo SARIMA por usuario y contador pronostica nueve contadores de actividad, mide cuánto se aleja lo observado de lo normal para ese usuario y entrega al SOC los casos más anómalos del día. En CERT r4.2 (1.000 usuarios, 500 días, 70 incidentes), con las mismas 10 alertas diarias que una regla global y una línea base estática, SARIMA encuentra 240 días maliciosos frente a 163 de la estática (+47 %) y 67 de 70 incidentes (estática, 64; global, 17).

Palabras clave: Amenaza interna · UEBA · Series de tiempo · SARIMA · Detección de anomalías · Fatiga de alertas

1. Introducción

La detección por firmas es eficaz ante amenazas conocidas, pero en gran medida ineficaz ante las desconocidas [5]. Una persona puede usar credenciales válidas para acciones maliciosas (MITRE ATT&CK T1078): lo anómalo es el patrón. Los SOC usan reglas de umbral y perfiles [5], pero un umbral fijo trata igual un lunes que un domingo: dispara con actividad normal y calla ante anomalías que no lo alcanzan. Los analistas reconocen que casi todas sus alarmas son falsos positivos y que revisarlas desgasta y desensibiliza [1], y así se pierden ataques [3].

La actividad de un usuario, como el tráfico de red [2], es una serie de tiempo: tiene ciclos diarios y semanales y depende de su historia. Por eso la línea base debería ser un modelo de series de tiempo por usuario. La pregunta es práctica: con las alertas que un SOC puede revisar, ¿ese modelo detecta más que una regla global y que una línea base estática, y cuánto aporta el ciclo semanal? El aporte es una analítica con modelos Box-Jenkins interpretables, uno por usuario y contador, evaluada con igual carga de trabajo y sin balancear las clases (0,32 % de días maliciosos), a diferencia de redes profundas como BRITD [6] y BTITD [8], con las que no se compara aquí.

2. Datos y método

Datos. CERT r4.2 [4] simula 1.000 usuarios durante 500 días con registros de sesiones, USB, archivos, correo, web y directorio. Su registro de incidentes describe 70 casos: fuga de información a WikiLeaks fuera de horario (30), robo de datos antes de renunciar (30) y sabotaje con la cuenta del supervisor (10). Un usuario-día es malicioso si tiene un evento del incidente.

Cómo funciona. La analítica corre como un proceso nocturno: (1) un proceso de extracción resume los registros en nueve contadores por usuario y día (sesiones, USB, archivos, correo y web, también fuera de 07:00 a 19:00); (2) para cada usuario y contador, un modelo pronostica el valor esperado del día y su *límite del 99 %*, el valor que un día normal no debería superar más de 1 vez de cada 100; (3) el puntaje del usuario es el mayor exceso sobre su pronóstico, en desviaciones estándar; (4) el SOC revisa los k usuarios con mayor puntaje. Los modelos usan $\log(1 + \text{conteo})$ y solo cuentan los aumentos.

Modelos. Se comparan la regla global (un umbral para todos), la línea base estática (media y desviación de cada usuario, recalculadas cada mes), la regla ingenua (hoy igual que hace una semana), ARIMA, SARIMA y SARIMAX (con la mediana del departamento). Box-Jenkins mostró estructura temporal: de 5.700 series con actividad, el 94 % tiene ciclo semanal y en el 96 % ADF (sin el promedio de cada día) y KPSS son compatibles con estacionariedad; por AIC se eligió SARIMA$(0, 0, 0)(1, 0, 1)_7$. Sus coeficientes ($\Phi \approx 1$, $\Theta \approx -1$) lo vuelven, en la práctica, un perfil por día de la semana que se actualiza lentamente; las series casi vacías (37 % de los ajustes) usan la media del usuario.

Evaluación. Se entrena hasta el 2010-06-09, antes de cualquier incidente, y se prueba hasta el 2011-05-16, reentrenando cada mes con 182 días, sin usar etiquetas [7], o, como control, una sola vez. Se mide cuánto se detecta con k alertas diarias y la precisión promedio (PR-AUC; al azar, 0,0032), con intervalos de confianza (IC) del 95 % por bootstrap de usuarios.

3. Resultados

Con igual carga de trabajo, los tres modelos de series de tiempo superan a las reglas en toda la Tabla 1. Con 10 alertas diarias, SARIMA encuentra 240 días maliciosos, frente a 163 de la estática (+47 %; IC del 95 % de la diferencia: 43 a 117) y 36 de la regla global. SARIMA supera a la estática con 1 a 30 alertas diarias, aun sin reentrenar, y en PR-AUC (+0,0062; IC: 0,0025 a 0,0108).

Sin tope diario, la regla global dispara 108 alertas al día (98 de cada 100 falsas); SARIMA, 18,5. La línea base estática necesita 18 alertas diarias para alcanzar los 240 días de SARIMA con 10. Un perfil por día de la semana sin modelo (otro enfoque temporal, cercano a lo que aprende SARIMA) también supera a la estática con cualquier número de alertas (con 10 diarias, 47 días más; IC: 24 a 74); frente a SARIMA encuentra menos con 3 a 17 alertas diarias y más con 18 o más. La ventaja se concentra en el robo de datos antes de renunciar, con 861 de los 986 días maliciosos; el póster (pág. 4) muestra un caso. El límite

Tabla 1. Detecciones con igual número de alertas diarias. Negrita: mejor valor.

	Días maliciosos detectados (de 986)				Con 10 alertas diarias		
Detector	3/día	5/día	10/día	20/día	Incidentes	Aciertos/100	PR-AUC
Regla global	16	19	36	42	17/70	1,1	0,0125
Línea base estática	52	82	163	258	64/70	4,8	0,0270
Regla ingenua	32	53	93	157	46/70	2,7	0,0118
Perfil semanal (control)	75	128	210	**322**	**67/70**	6,2	**0,0361**
ARIMA	**85**	126	220	293	**67/70**	6,5	0,0346
SARIMA	81	**146**	**240**	300	**67/70**	**7,0**	0,0331
SARIMAX	83	131	234	305	65/70	6,9	0,0330

es conservador: los días normales lo superaron entre 0,2 % y 0,8 % de las veces según el contador (nominal, 1 %). En PR-AUC no hubo evidencia de diferencias entre los tres modelos, pero SARIMA es el más estable: sin reentrenar conserva su PR-AUC (0,0339) y ARIMA cae a 0,0204, bajo la estática (0,0277). Ljung-Box no rechaza la ausencia de autocorrelación en el 95 % de los ajustes iniciales de SARIMA y en el 82 % de los mensuales (se esperaría 95 %), frente al 9 % de ARIMA.

4. Conclusiones

Un modelo de series de tiempo aprende el ritmo de cada usuario y un umbral fijo no: con 10 alertas diarias, los tres modelos detectan entre 35 % y 47 % más días maliciosos que la estática y SARIMA, 6,7 veces los de la regla global; el analista revisa 14,2 alertas por cada día malicioso encontrado en vez de 20,9, lo que ayuda a reducir la fatiga de alertas. El ritmo semanal hay que estimarlo: repetir el día de la semana anterior encuentra 93 días, no 240. No ve costumbres del usuario ni acciones sin cambio de volumen; ahí sirven la regla global, el EDR y las firmas. Muestra viabilidad en datos sintéticos; una alerta no confirma un ataque.

Referencias

1. Alahmadi, B.A., Axon, L., Martinovic, I.: 99 % false positives: A qualitative study of SOC analysts' perspectives on security alarms. In: 31st USENIX Security Symposium (2022)
2. Brutlag, J.D.: Aberrant behavior detection in time series for network monitoring. In: 14th Systems Administration Conference (LISA 2000). pp. 139–146. USENIX (2000)
3. Hassan, W.U., et al.: NoDoze: Combatting threat alert fatigue with automated provenance triage. In: NDSS Symposium (2019)
4. Lindauer, B.: Insider threat test dataset (2020). `https://doi.org/10.1184/R1/12841247.v1`
5. Scarfone, K., Mell, P.: Guide to intrusion detection and prevention systems (IDPS). Tech. Rep. SP 800-94, National Institute of Standards and Technology (2007)
6. Song, S., Gao, N., Zhang, Y., Ma, C.: BRITD: behavior rhythm insider threat detection with time awareness and user adaptation. Cybersecurity **7**, 2 (2024)

7. Tashman, L.J.: Out-of-sample tests of forecasting accuracy: an analysis and review. International Journal of Forecasting **16**(4), 437–450 (2000)
8. Zhang, C., et al.: BTITD: an insider threat detection method based on behavior-timestamp dual-stream network. Cybersecurity **9**, 179 (2026)